

שיעור מספר 5

3.12.25

★ חלק א'

הנושא: תיקון 13 – השפעתו על החוק, מאגרים, סמכויות הרשות ותפקיד ה - DPO

מרצה: עלי קולדרון

1. למה היה צורך בתיקון 13?

- החוק ישן (1981), פרק מאגרים מ-1992 – לא מותאם לעידן הדיגיטלי.
- רשות חלשה ללא עיצומים אפקטיביים.
- מנגנון רישום מאגרים היה כמעט חסר משמעות (5% מהרשומות בפועל).
- דרישה בינלאומית לשמור התאמה לאיחוד האירופי.

2. מה השתנה בתיקון 13?

2.1 סמכויות הרשות

- הרשות מוגדרת כרגולטור עצמאי ומקבלת:
 - סמכות להטיל עיצומים כספיים גבוהים.
 - סמכות להוציא צו הפסקת עיבוד מידע.
 - סמכות לדרוש הפסקת מערכת עד תיקון כשלי האבטחה.

2.2 רישום מאגרים ← הודעה על מאגרים מסוכנים

- רישום מאגר נשאר רק ל:
 - גופים ציבוריים (מדינתיים).
 - מי שסוחר במידע.
- חדש:
 - חובת הודעה לרשות על מאגר הכולל:

- מעל 100,000 נושאי מידע,
- מידע בעל רגישות מיוחדת.

2.3 הגדרות חדשות

- "עיבוד מידע" = כל פעולה: איסוף, אחסון, צפייה, קריאה, מחיקה.
- "מידע בעל רגישות מיוחדת" – רשימה בחוק (פיננסי, רפואי, ביומטרי, גנטי, עבר פלילי ועוד).
- חשוב: יש פער בין ההגדרה החדשה בחוק לבין "מידע רגיש" בתקנות האבטחה.

2.4 מינוי ממונה פרטיות (DPO)

- חובה למנות DPO בארגונים מסוימים (למשל מאגרים ברמת אבטחה גבוהה).
- $DPO =$
 - איש קשר מול הרשות,
 - מלווה אירועי אבטחה,
 - כותב מדיניות,
 - מוודא עמידה בחוק.

2.5 זכויות נושאי המידע

- חייבים להזכיר זכות עיון בעת איסוף מידע.
- אימתן זכות עיון תוך 30 יום ← עיצומים משמעותיים.

3. בעל שליטה לעומת מחזיק

- בעל שליטה = קובע מטרות עיבוד, משתמש במידע לעצמו.
- מחזיק = מעבד עבור בעל שליטה (הוסטינג, SaaS)
- רוב הוראות החוק חלות על שניהם, אבל:
 - בעל השליטה ← אחראי לדיווח על מאגר מסוכן.
 - מחזיק ← חייב לעמוד בהוראות אבטחה ובפיקוח.

4. אכיפה (מה הרשות עושה בפועל)

4.1 מסלול פלילי

- דורש יסוד נפשי (כוונה/מודעות).
- למשל עובדים ש"גנבו וניצלו" מידע.

*כדי להוכיח את זה חייבים "פורנזיקה".

4.2 מסלול מנהלי

- פיקוח: בדיקות רוחביות למגזרים.
- בירור מנהלי: חשד להפרה ← דרישות מסמכים, חקירות, עיצומים, צווי הפסקת עיבוד.

5. אירועי אבטחה חמורים

- "אירוע אבטחה חמור" = כל עיבוד מידע ללא הרשאה.
- חובה לדווח לרשות:
 - ברמת אבטחה גבוהה – כל אירוע.
 - ברמת אבטחה בינונית – רק אם פוגע בחלק מהותי של המאגר.
 - בסיסית – אין חובת דיווח (אבל יש חובת טיפול).

המשך, הנושא: פרקטיקה של פרטיות – תפקיד ה־ DPO, אכיפה, התנהלות נכונה, אירועים בארגון

(אותו שיעור, אבל עם פוקוס אחר לחלוטין)

1. תפקיד ה־ DPO פועל (לא לפי החוק – לפי המציאות)

1.1 תפקידים אמיתיים של DPO

- שומר הסף של הפרטיות בארגון.
- מגשר בין:

- הנהלה,
- CISO,
- יועמ"ש,
- מחלקות עסקיות,
- עובדים.
- צריך בודזמנית:
 - לאפשר חדשנות עסקית,
 - להגן על זכויות נושאי המידע,
 - להגן על הארגון מפני סנקציות.

1.2 הקונפליקט התמידי

- DPO = חלק מהארגון ← צריך לעזור לארגון להצליח.
- אבל גם "הזרוע הארוכה של הרשות" בתוך הארגון.
- לכן:
 - חייב לבנות אמון,
 - חייב להיות מעורב בתכנון פרויקטים, (Privacy by Design)
 - לא יכול להיות "לא" מוחלט ← חייב להיות יצירתי.

2. ההתנהלות מול הרשות

2.1 מה הרשות מצפה לראות בארגון

- נהלי פרטיות מסודרים וכתובים.
- מסמכי הגדרות מאגר.
- נוהלי הרשאות, לוגים, נוהל אירועי אבטחה.
- תיעוד של תהליכים ולא רק הצהרות.

2.2 איך נראית בדיקת פיקוח

- שולחים דרישות מסמכים.
- מבקשים לראות הסכמים עם ספקים, נהלים, מדיניות.
- לעיתים מגיעים לביקור פיזי.
- פחות מעניינים "דוחות יפים" – יותר מעניינת היכולת להראות עקביות ויישום בשטח.

3. התנהלות נכונה באירוע אבטחה

3.1 תמיד לדווח ל־ DPO ברגע שיש חשש לדלף

–גם אם לא ידוע עדיין כלום.

3.2 ה־ DPO בדיון משבר עושה:

- הערכת חומרה עם ה־ CISO.
- ייעוץ משפטי עם היועמ"ש.
- החלטה על דיווח לרשות.
- הכנת מסרים ללקוחות/עובדים.
- ניהול תיעוד מלא של כל פעולה.

3.3 מה "NOT TO DO"

- לא להמתין "עד שיהיה ברור".
- לא לנסות להסתיר מידע על אירוע מה־ DPO
- לא לדחות דיווח כשיש חשש אמיתי.

4. הבדל בין מדיניות לפעילות בפועל

המרצה הדגיש:

“רשות הפרטיות לא מתרשמת ממסמכים – היא מתרשמת מתיעוד של ביצוע”.

למשל:

- מדיניות הרשאות ≠
“פלט אקראי מהמחשב של מי שיש לו גישה.”
- נוהל אירועי אבטחה ≠
“כתבנו מסמך.”
- צריך:
 - סקירות תקופתיות,
 - תיעוד החלטות,
 - ניהול מערכת הרשאות,

5. מה הרשות רואה כ"חמורות" ביותר

- אימתן זכות עיון.
- שימוש במידע בניגוד למטרה (הפרת צמידות).
- מסירת מידע לגורם שלישי ללא הסכמה/יידוע.
- היעדר אבטחת מידע בסיסית.
- אידידיוח על אירוע חמור.

סיכום חלק הראשון של השיעור

1. תחילה המרצה התמקד ב־**מה החוק דורש**, מה השתנה, מה חובת ארגונים, איך מתנהלת הרשות, ומה תפקיד ה־ DPO בתוך זה.

2. לאחר מכן התמקד, ב־**איך DPO מתנהל בפועל**, איך הרשות עובדת באמת, מה עושים באירוע, מה הטעויות הנפוצות, ואיך בונים ארגון שמסוגל לעמוד בביקורת.

המשך	תחילת השיעור
פרקטי, תפעולי	משפטי, רגולטורי
איך מנהלים פרטיות בארגון	מה החוק אומר
התנהלות, DPO, ניהול משברים, אירועים, נהלים	תיקון 13 – הגדרות, סמכויות, רישום, הודעות
עבודה מול הנהלה, CISO, משפטי	אחריות בעל שליטה/מחזיק
תרבות פרטיות ויישום בשטח	זכויות נושאי מידע

★ המשך משיעור 5 – חלק שני: פרטיות בארה"ב לעומת אירופה

מרצה: אבישי קליין – ראש תחום פרטיות וסייבר

חלוקה ברורה לשני נושאים עיקריים

1. הבנת ה-GDPR (רגולציית אירופה) ומה הופך אותה לבסיס השוואתי.
2. הבנת רגולציית פרטיות בארה"ב, הפערים, ההיגיון התרבותי, ההחוקים המרכזיים.

חלק 1 GDPR – כסטנדרט עולמי

למה ה-GDPR הוא רגולציית הפרטיות החשובה בעולם?

- נכנס לתוקף. 2018 :
- יצר שני שינויים:
- 1. **אכיפה וקנסות קיצוניים** 10–20 –מיליון אירו / 2–4% מהמחזור. ← הפך את הפרטיות לנושא שמנהלים מפחדים ממנו באמת.
- 2. **תחולה חוץ - טריטוריאלית** – חל גם על חברות מחוץ לאירופה, אם:
 - הן מוכרות שירותים/מוצרים באירופה
 - או עוקבות אחרי התנהגות משתמשים אירופאים

למה חשוב לאירופה להגן על פרטיות?

- מושפע עמוקות מההיסטוריה האירופית (פגיעה בזכויות אדם בתקופות אפלות).
- זכויות אדם בראש מודל קבלת ההחלטות.
- פרטיות = זכות יסוד דמוקרטית.

חלק 2 – פרטיות בארה"ב: גישה שונה מהקצה לקצה

★ הגישה האמריקאית מבוססת על:

צרכנות, מסחר ותחרות – לא זכויות אדם

- פרטיות בארה"ב אינה זכות יסוד.
- הרגולציה נועדה בעיקר להגן על צרכנים בתוך פעילות מסחרית, לא בהקשר מוסרי.

אין חוק פרטיות פדרלי בארה"ב (נכון ל-2025)

← הפרטיות מנוהלת ב:

1. חוקים פדרליים סקטוריאליים
2. חוקי פרטיות מדינתיים
3. אכיפה אגרסיבית של ה-FTC (נציבות הסחר הפדרלי)

1) חוקים פדרליים – סקטוריאליים בלבד

חוק	תחום	מה הוא מגן	מה נדרש
HIPAA	מידע רפואי	מטופלים, מוסדות רפואיים, ספקים	אבטחת מידע, הסכמות, דיווח על דלף
GLBA	מידע פיננסי	צרכני בנקים	שמירה על מידע פיננסי, גילוי, הגנות טכניות
COPPA	ילדים	משתמשים מתחת גיל 13	הסכמת הורים + מדיניות מותאמת לילדים

שים לב: החוקים אינם חלים על כלל המידע – רק על מגזר מוגדר.
זו נקודת חולשה משמעותית בהשוואה לאירופה.

(2) חוקי פרטיות מדינתיים

החל מ-2025: כ-20 מדינות כבר אימצו חוקי פרטיות, CCPA (וירג'יניה, קולורדו, טקסס ועוד).

✓ הדוגמה החשובה ביותר – CCPA/CPRA: קליפורניה

חל על עסקים שיש בהם אחד מאלה:

- 25 מיליון דולר הכנסות
- מידע על >100,000 צרכנים קליפורנים
- מעל 50% מההכנסות ממכירת מידע (= Data Broker)

מה זכויות הצרכן?

- לדעת איזה מידע נאסף
- למחוק מידע
- להתנגד למכירת מידע אישי: הודעת (Do Not Sell)
- לקבל העתק ולבצע ניידות מידע

אכיפה:

- תובע מדינתי
- קנסות כבדים
- תביעות ייצוגיות

(3) FTC - הגוף האכיפתי הכי מסוכן בארה"ב

ה-FTC - משתמש בשני מושגים כדי להעניש חברות:

1. **Unfair** – לקיחת מידע או פגיעה בצרכן בצורה לא הוגנת
2. **Deceptive** – מצג שווא במדיניות הפרטיות / הסתרת מידע

מה המשמעות בפועל?

- אם החברה כותבת שהיא שומרת מידע לצורך X ← אבל בפועל מעבירה לצד ג' ← זה מספיק לקנס כבד.
- הדלפת מידע ללא הגנות מספיקות = פגיעה בצרכן ← עילה לקנס.

מסקנה: האמריקאים לא צריכים חוק פורמלי כדי להעניש. ה-FTC ממציא "אכיפה דרך חוקי צרכנות".

★ דוגמאות מפתח שהמרצה הדגיש

✓ מקרה ספורה – (Sephora) קנס ראשון ב-CCPA

- השתמשו ב-Google Analytics ללא הצבת כפתור Do Not Sell
 - לא כיבדו בקשות של משתמשים
 - קנס של מעל מיליון דולר
- ← מסר ברור: באנר לא מעניין – חייבים מנגנון עובד!

נושא מיוחד: חוקים ביומטריים בארה"ב – BIPA (אילינוי)

מה החוק דורש?

- הסכמה מפורשת לפני איסוף מידע ביומטרי
 - גילוי: מה אוספים? למה? לכמה זמן?
 - מחיקה בזמן קבוע מראש
 - איסור להעביר לצד ג' בלי הסכמה
- ← חוק מפחיד – מוביל לתביעות ענק.

תוצאה: הרבה חברות AI חוסמות משתמשים מאילינוי כדי לא להסתכן.

נושא נוסף: ילדים (COPPA)

מה חובה?

- לקבל הסכמה של ההורים לפני כל איסוף מידע מתחת לגיל 13
- מדיניות פרטיות בשפה שילד יכול להבין
- מנגנון אימות שההורה באמת מאשר (אימייל מאומת / מסמכים)

אכיפה: ה-FTC תוקף חזק – כולל חברות משחקים.

השוואה מהירה : GDPR vs. USA

נושא	אירופה (GDPR)	ארה"ב
גישה	זכויות אדם	צרכנות
תחולה	אחידה לכל אירופה	מפוזרת – מדינות + מגזרים
הסכמה	חזקה וברורה	לא תמיד נדרשת
העברת מידע	מוסדר מאד	לא מוסדר ברמה פדרלית
ילדים	מידע רגיש במיוחד	COPPA - רגולציה ספציפית
ביומטרי	חלק מהמידע הרגיש	חוק מדינתי (BIPA)
קנסות	קבועים בחוק, גבוהים	תלוי ברגולטור ובמדינה
Do Not Sell	לא קיים	חובה במדינות מסוימות

מסקנות

1. ✓ בארה"ב אין חוק אחוד ← הפרטיות תלויית הקשר

צריך לזהות:

- האם זה מידע רפואי ← HIPAA ?
- ילדים ← COPPA ?
- ביומטרי ← BIPA ?
- צרכנות כללית ← CCPA/CPRA ?

2. ✓ אירופה מחמירה הרבה יותר

GDPR = סטנדרט זהב ← אם אתה עומד ב-GDPR אתה מכוסה ~75% בארה"ב.

3. ✓ ה-FTC מסוכן יותר מכל רגולטור אירופי

כי הוא מעניש על כל "אי הוגנות" גם אם לא כתוב בחוק.

4. ✓ בארה"ב חשוב מאוד:

- Notice at Collection (יידוע לפני איסוף)
- Do Not Sell
- מדיניות פרטיות ברורה
- בדיקות תקופתיות לאתר (קוקיז חדשים, שימושים חדשים)